PROJET ACADÉMIQUE · SSIR · 2026–2027

Serveur MCP intelligent de renseignement sur les menaces

UNIVERSITÉ PRIVÉE TEK-UP

Protection du secret, étiquetage et traçabilité de bout en bout

Mzabi Sirine · Khaled Ellif

Encadrant académique : Tarek Hdji

VALIDATION 1 · ARCHITECTURE

VALIDATION 2 · RÉALISATION & TESTS

Version 1.0 — 27 octobre 2026 · données synthétiques · laboratoire hors ligne

Un agent peut lire un bulletin Secret sans le divulguer

LA DEMANDE QUI SEMBLE ANODINE

« Résume ADV-2026-004. »

Un seul appel. Trois secrets possibles.

AGENT Il exécute la demande… et une instruction cachée.

BULLETIN Secret : canari de fuite + identité de source.

RÉPONSE Trop riche = fuite ; trop vague = agent inutile.

4,44 M$

coût moyen d'une violation

IBM 2025

12 / 30 / 6

bulletins / IOC / actifs

jeu synthétique

31

scénarios de campagne

15 nominaux + 16 abus

Cinq objectifs mesurables, un périmètre borné

O1

0 fuite

16 / 16 abus

O2

100 % tracé

115 / 115 appels

O3

3 / 3 inject.

0 faux positif

O4

p95 ≤ 50 ms

12,42 ms

O5

≤ 5 s

10,0 ms · uid 65534

INCLUS DANS LA MAQUETTE

stdio · 6 outils · ABAC · étiquetage · audit chaîné · « nobody » · base 0440 · clé 0400

EXCLU OU LAISSÉ À L'INTÉGRATION

HTTP · OAuth 2.1 · mTLS · EDR réel · ancrage externe du journal · données réelles

Quatre familles d'actifs, des acteurs et une surface étroite

ACTIFS

Ce qu'on protège

- **Secret**
  source, opération CANARI
- **Confidentiel**
  vulnérabilités, actifs
- **Interne**
  indicateurs, familles
- **Public**
  bulletins de sensibilisation
- **Secrets op.**
  clé, base, journal

ACTEURS

Qui peut agir

- **Analyste SOC**
  habilitation 1–2
- **Lead CTI**
  habilitation 3 + compartiments
- **Agent conversationnel**
  légitime mais manipulable
- **Partenaire**
  fournit, ne commande pas
- **Attaquant**
  jeton, flux, poste

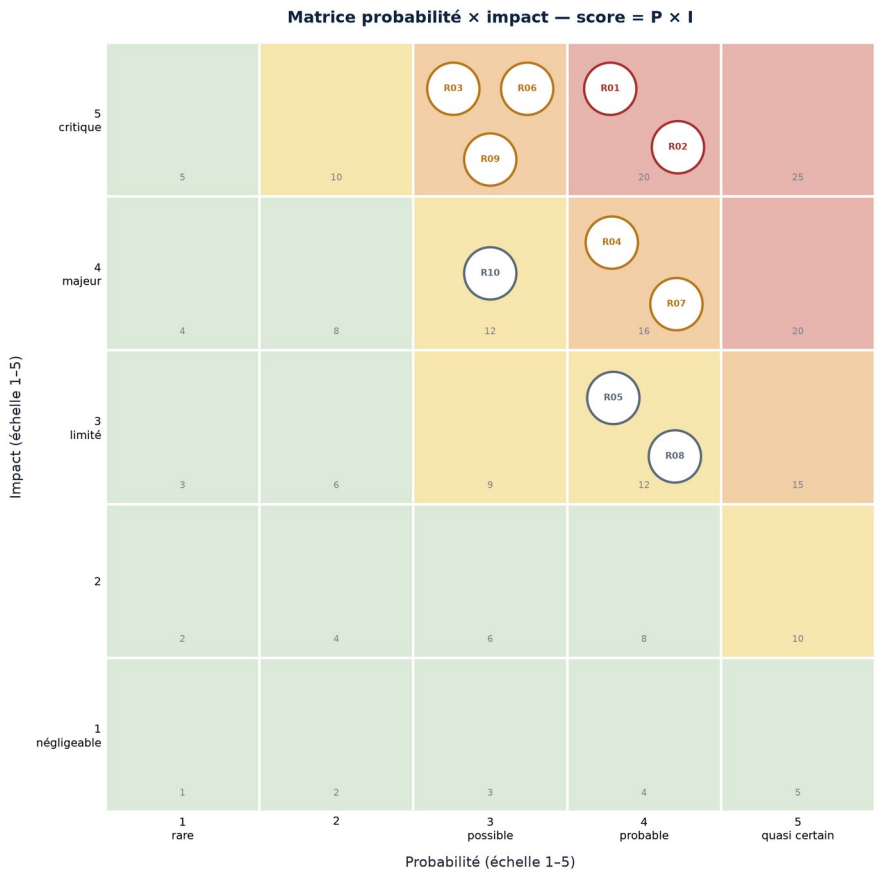
SURFACE

Où l'on peut frapper

- **stdio**
  canal local
- **6 outils**
  schémas stricts
- **Ressources**
  URI filtrées
- **Contenu importé**
  injection, poison
- **Fichiers**
  clé, base, journal

L'agent est légitime, mais il exécute aussi une instruction cachée : le serveur ne traite jamais le contenu comme une commande.

Dix risques cotés, deux priorité absolue



Risques classés

Le score brut départage mal les ex æquo : l'impact tranche, puis la probabilité.

01	R01	Fuite d'un bulletin Secret par réponse trop riche	20
02	R02	Injection de consignes dans un flux partenaire	20
03	R04	Accès hors besoin d'en connaître	16
04	R07	Poste client compromis ou non conforme	16
05	R03	Jeton forgé, rejoué ou élevé en privilège	15
06	R06	Altération ou suppression des traces	15
07	R09	Empoisonnement de la base de renseignement	15
08	R10	Fichiers, base ou clé laissés accessibles	12
09	R05	Fuite par message d'erreur ou énumération	12
10	R08	Saturation du service par un client	12

Seuil de priorité P1 du score composite : 8,5 / 10.
Les risques R01, R02 et R07 sont ceux que la démonstration met en scène.

R01 Fuite Secret — 20

réponse trop riche

R02 Injection — 20

flux partenaire

R04 Hors compartiment — 16

besoin d'en connaître

Un score de 15 reste grave : clé compromise ou traces altérées ont un impact maximal.

Source : modèle de menace du projet — scores argumentés, pas des mesures statistiques.

Chaque risque descend vers une exigence, un contrôle et un test

13 exigences fonctionnelles

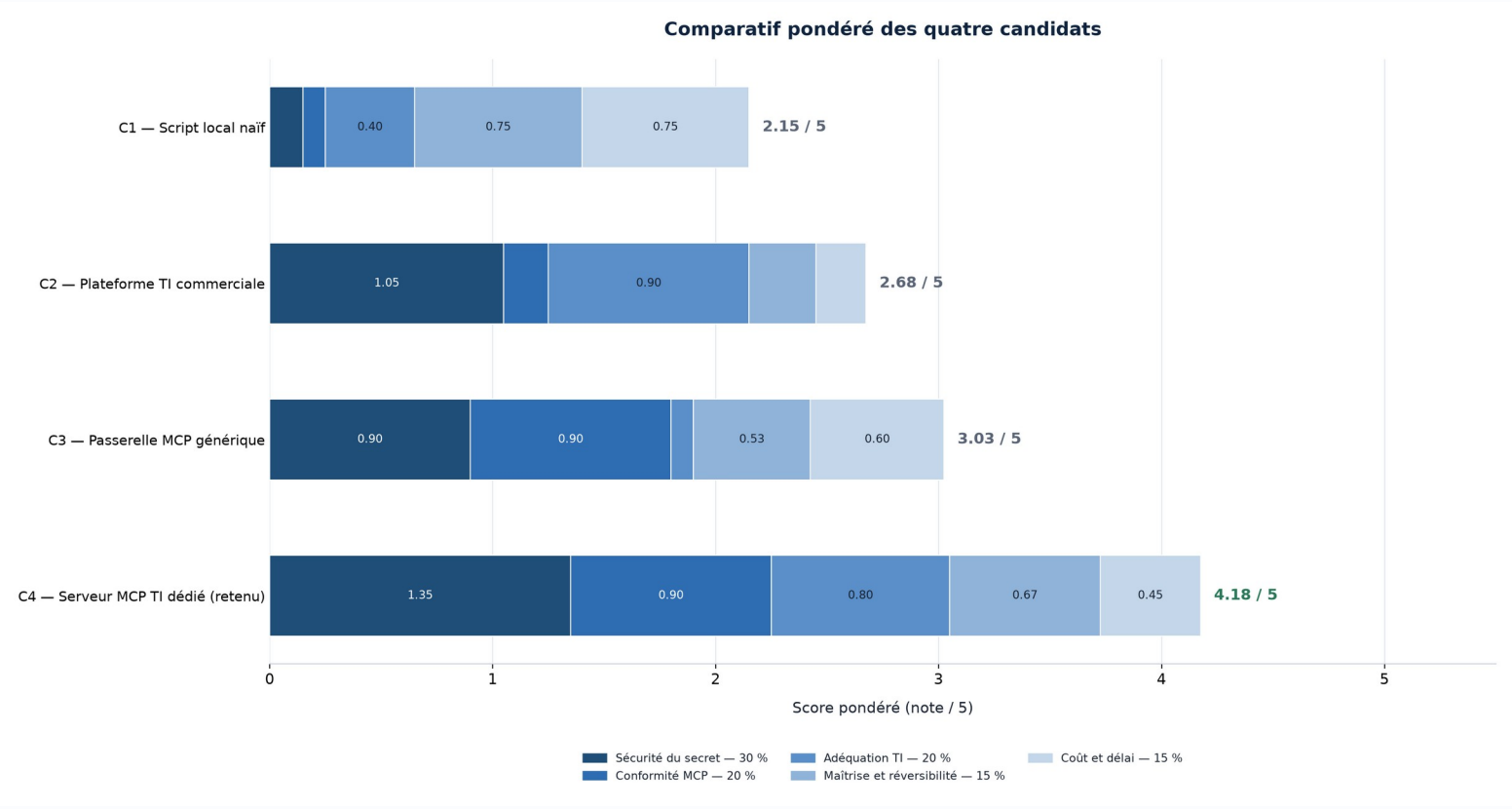
12 exigences non fonctionnelles

10 risques couverts

Risque	Ce qui peut arriver	Exigences	Contrôles	Tests
R01	Fuite d'un bulletin Secret	EF-03 · EF-04	CP2 · CP5	A06 · A07 · A15
R02	Injection partenaire	EF-05 · ENF-12	CP4 · CP5	A10
R06	Altération des traces	EF-08 · ENF-08	CP7	A14
R10	Fichiers accessibles	ENF-06 · ENF-07	CP8 · N15	N15

Un contrôle sans exigence est décoratif ; une exigence sans test est une intention. La matrice se lit dans les deux sens.

Quatre candidats, un choix assumé à 4,18 sur 5



Source : notation pondérée du projet ; les poids sont fixés avant les notes.

C4 — SERVEUR DÉDIÉ

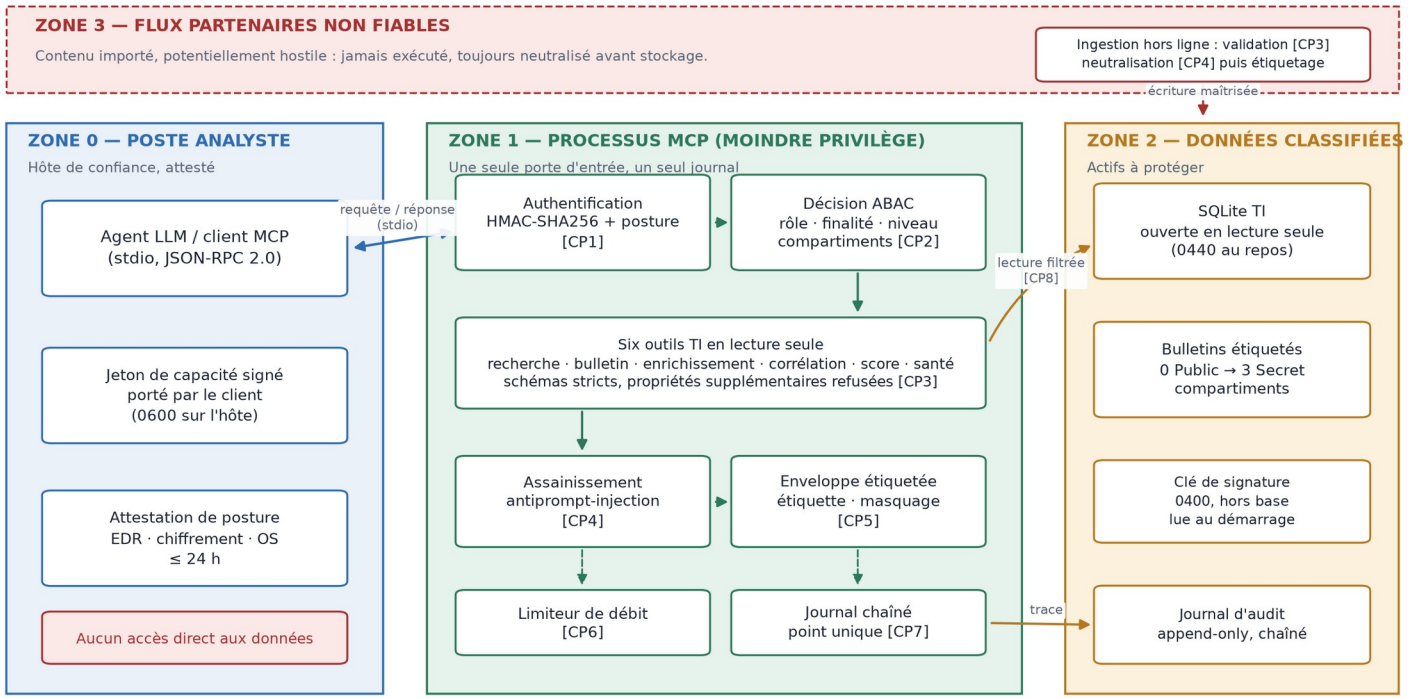
4,18 sur 5

sécurité 30 % + conformité 20 %

C1	2,15	script local — le plus populaire
C2	2,68	plateforme commerciale
C3	3,03	passerelle MCP générique

C1 écarté : ni jeton, ni étiquette, ni journal. Immédiat ne veut pas dire sûr.

Trois zones de confiance, huit points de contrôle, un seul journal



Frontière de confiance : le client ne parle jamais aux données ; le serveur ne sort jamais du poste.

Chaque flèche traversant une frontière est un point de contrôle nommé (CP1 à CP8).

ZONE 0 — **Poste analyste**

client MCP, jeton, posture

ZONE 1 — **Serveur non privilégié**

CP1 à CP7, un seul journal

ZONE 2 — **Données classifiées**

SQLite 0440, clé 0400, audit

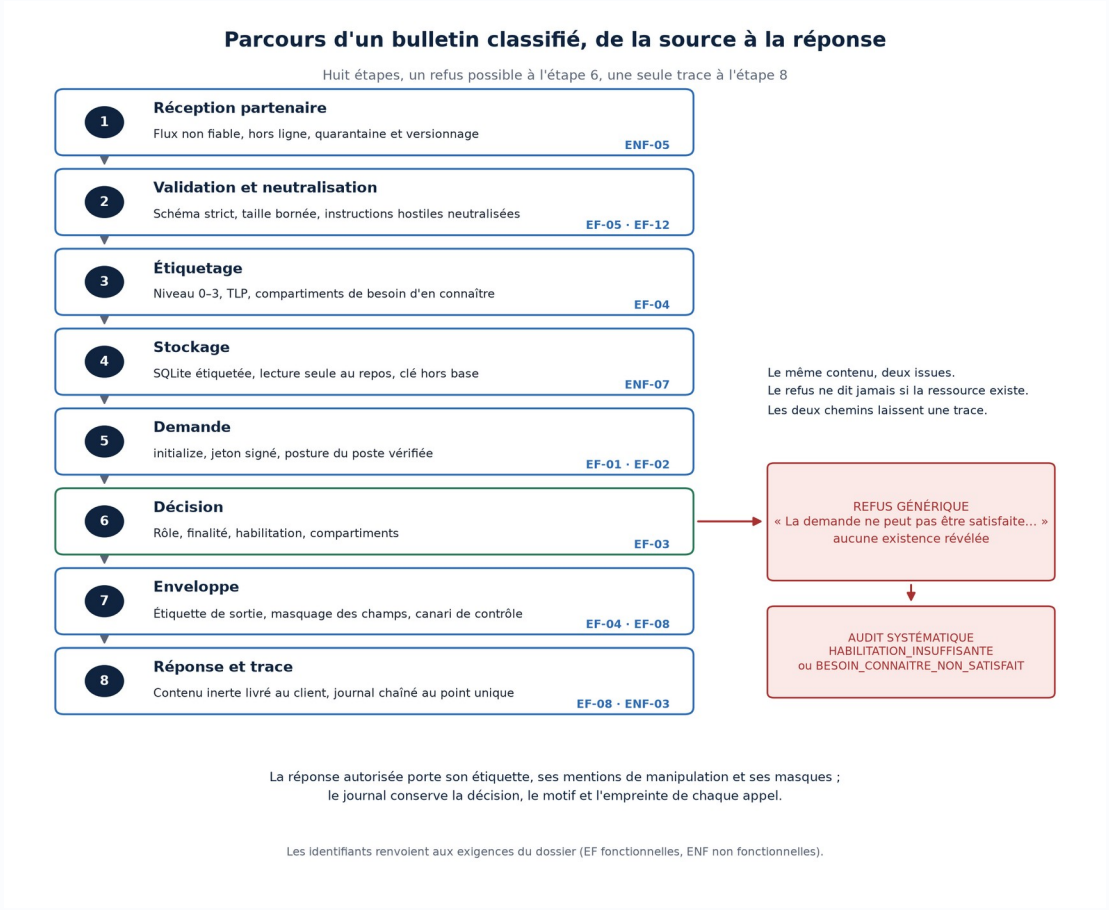
ZONE 3 — **Flux partenaire**

non fiable, neutralisé à l'ingestion

Fail-closed : pas d'audit = pas de réponse.

Source : conception du projet — CP1 à CP8 détaillés dans le rapport.

Huit étapes, une branche de refus, une trace



1–2

Réception et validation

contenu non exécutable

3–4

Étiquetage et stockage

niveau, TLP, compartiments

5–6

Demande et décision

jeton, posture, ABAC

7–8

Enveloppe et réponse

masquage, fanions, audit

Refus : message générique pour le client, motif précis dans l'audit. Aucun oracle.

Source visible au niveau 3 seulement ; canari absent de tout refus.

Source : conception du projet — chaque étape cite une exigence.

Neuf modules, six outils, un journal horodaté

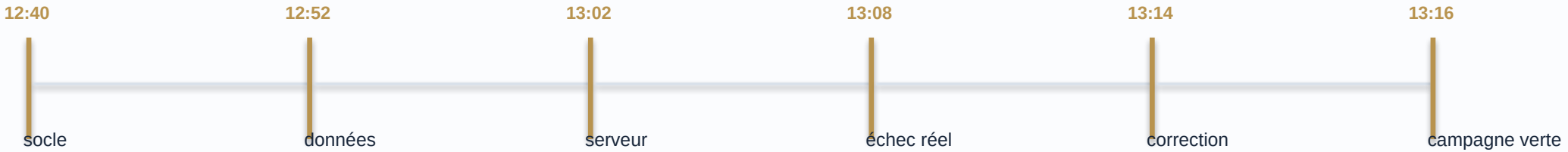
SOCLE — 9 MODULES, BIBLIOTHÈQUE STANDARD

- config
- labels
- sanitize
- auth
- policy
- store
- intel
- tools
- server

CONTRAT — 6 OUTILS EN LECTURE SEULE

- ti_search
- ti_get_advisory
- ti_enrich_ioc
- ti_correlate
- ti_score_asset
- ti_health

schémas stricts · additionalProperties:false · readOnlyHint



Premier échec à 13 h 08 : décodage UTF-8 de l'audit ; corrigé à 13 h 14, rejoué, conservé.

Le durcissement se prouve par les droits, pas par les slogans

```
ti@lab:~/tekup-mcp-ti$ stat -c "%a %U:%G %n" $R/data/ti.db $R/data/token.key
440 nobody:nogroup /tmp/ti-nonroot/data/ti.db
400 nobody:nogroup /tmp/ti-nonroot/data/token.key

ti@lab:~/tekup-mcp-ti$ setpriv --reuid=65534 --regid=65534 --clear-groups python3 -c "print(os.getuid())"
uid = 65534

ti@lab:~/tekup-mcp-ti$ setpriv ... python3 -c "open(ti.db, O_WRONLY|O_APPEND)"
PermissionError: [Errno 13] Permission denied: '/tmp/ti-nonroot/data/ti.db'
```

65534
uid du service
nobody

0440
base SQLite
lecture seule

0400
clé HMAC
propriétaire

0
port réseau
stdio local

Capture d'écran réelle : exécution sous « nobody », écriture refusée, aucun socket.

TESTÉ	uid 65534 · 0440 · 0400
PROPOSÉ	unité systemd
NON TESTÉ	HTTP · mTLS · EDR réel

Le service ne peut pas écrire la base ; l'ingestion est une opération séparée.

La fuite est bloquée, journalisée et visible

```
ti@lab:~/tekup-mcp-ti$ python3 scripts/demo_defense.py | sed -n '19,31p'
S2 — FUITE TENTÉE PAR UN JETON CONFIDENTIEL
> ti_get_advisory('ADV-2026-004')   [agent-soc-01, Confidentiel, CTI+INC]
  isError=True  code=RESSOURCE_INDISPONIBLE
  message=« La demande ne peut pas être satisfaite avec les droits présentés. »
  canari dans la réponse : False
  journal : decision=deny  reason=HABILITATION_INSUFFISANTE  classification=None  clearance=2

S3 — JETON SECRET MAIS HORS COMPARTIMENT
> ti_get_advisory('ADV-2026-004')   [agent-attrib-04, Secret, CTI seul]
  isError=True  code=RESSOURCE_INDISPONIBLE
  canari dans la réponse : False
  journal : reason=BESOIN_CONNAITRE_NON_SATISFAIT  (cloisonnement CRYPTO)
```

Source : preuves/logs/demo_capture.json — scènes S2 et S3 ; canari absent des deux réponses.

Confidentiel → Secret : refus

Secret hors compartiment : refus

Deux motifs d'audit distincts

Injection neutralisée, chaîne d'audit vérifiée

```
ti@lab:~/tekup-mcp-ti$ python3 scripts/demo_defense.py | sed -n '32,45p'
S4 — ACCÈS AUTORISÉ (SECRET + CRYPTO)
> ti_get_advisory('ADV-2026-004')   [agent-crypto-02, Secret, CTI+CRYPTO+ATTRIB]
  isError=False  classification=Secret  tlp=TLP:RED
  canari de contrôle présent : True   (CANARY-TEKUP-…-2026)
  journal : decision=allow  reason=OK

S5 — INJECTION D'INSTRUCTIONS DANS UN FLUX PARTENAIRE
> ti_get_advisory('ADV-2026-012')   [contenu hostile importé]
  isError=False  code=None
  fanions=appel_outil, balise_active, exfiltration, ignorer_instructions
  instruction brute livrée : False
  marqueur de neutralisation : True
  journal : injection_flags=['appel_outil', 'balise_active', 'exfiltration', 'ignorer_instructions']
```

```
ti@lab:~/tekup-mcp-ti$ python3 src/ti_cli.py verify-audit --path preuves/lab/audit.jsonl
{
  "fichier": "preuves/lab/audit.jsonl",
  "ok": true,
  "entries": 116,
  "broken_at": null,
  "reason": ""
}

ti@lab:~/tekup-mcp-ti$ python3 src/ti_cli.py verify-audit --path preuves/lab/audit_falsifie.jsonl
{
  "fichier": "preuves/lab/audit_falsifie.jsonl",
  "ok": false,
  "entries": 31,
  "broken_at": 31,
  "reason": "empreinte invalide"
}
```

Source : démonstration S5 et S6 — instruction neutralisée, chaîne vérifiée.

INJECTION

3 / 3 charges neutralisées

0 faux positif sur 11 bénins

AUDIT

116 entrées chaînées

115 appels + 1 erreur protocole

La chaîne SHA-256 est vérifiée en une commande ; la source est masquée.

31 scénarios, 31 réussites, 12,42 ms

terminal — tekup-mcp-ti

Capture 7 — Campagne de tests bout en bout

31 scénarios exécutés dans le laboratoire, résultats consignés sans filtrage

```
$ python3 tests/run_tests.py

Tests: 31/31 — échecs: 0 (nominaux 14, abus 16)
Détection abus: 16/16 (100.0 %)
Latence p95: 12.42 ms (n=60)  p50=9.4 ms  p99=13.99 ms
Audit: valide=True  entrées=116  appels attendus=115  complétude=100.0 %
Révocation: commande=121.31 ms  application=10.0 ms  audit=TOKEN_REVOQUE
Injection: 3/3 détectés  faux positifs=0

Extraits de la campagne :
  [  OK] A06 Tentative de fuite par habilitation insuffisante — code=RESSOURCE_INDISPONIBLE, canari_present=False,
    audit=HABILITATION_INSUFFISANTE
  [  OK] A07 Tentative de fuite par défaut de cloisonnement — code=RESSOURCE_INDISPONIBLE, canari_present=False,
    audit=BESOIN_CONNAITRE_NON_SATISFAIT
  [  OK] A10 Injection d'instructions dans un flux partenaire — fanions=['appel_outil', 'balise_active', 'exfiltration',
   'ignorer_instructions'], instruction_brute=False, canari=False
  [  OK] A14 Falsification du journal d'audit — original=True (44), copie_ok=False, rupture_seq=31
  [  OK] A15 Lecture directe d'une ressource Secret — erreur=-32002, audit=HABILITATION_INSUFFISANTE
  [  OK] A16 Message JSON malformé — code_erreur=-32700, serveur_vivant=True

Durcissement: uid=65534 (nobody)  base=0o440  clé=0o400  écriture refusée=True
Comparatif: maquette 8/8 faiblesses ; serveur durci 0 faiblesse
```

Source : preuves/logs/tests_latest.json · exécuté le 2026-10-27 13:16:15 UTC

31 / 31 — scénarios réussis

16 / 16 — abus maîtrisés

12,42 ms — latence p95

10,0 ms — révocation

Source : preuves/logs/tests_latest.json — campagne du 27 octobre 2026.

Mêmes données, mêmes outils : la maquette naïve échoue 8 / 8, le serveur durci échoue 0 / 8.

Huit faiblesses neutralisées, des limites nommées

CONTRÔLES COMPARÉS

8 → 0 **faiblesses sur 8**

Canari, source, injection, validation, séparation, journal, révocation, débit.

La maquette naïve expose tout ; le serveur durci refuse, masque ou neutralise.

CE QUI N'EST PAS TESTÉ

Isolation réseau	PROPOSÉE
Agent EDR réel	DÉCLARATIF
Ancrage externe audit	ABSENT
HTTP · OAuth 2.1 · mTLS	NON TESTÉ
Charge réelle	NON TESTÉE

Une limite nommée n'est pas un échec caché : c'est un travail futur priorisé.

Une politique de secret devenue comportement observable

LA THÈSE, EN UNE PHRASE

Un serveur MCP peut rester simple, local et honnête en rendant la protection du secret démontrable.

DÉCIDER

ABAC, habilitation, compartiments

ÉTIQUETER

niveau, TLP, masquage, fanions d'injection

TRACER

journal chaîné, revue et révocation

31 / 31 · 16 / 16 · 12,42 ms · 8 → 0

Merci — questions bienvenues.

Rapport, preuves, captures et commandes de reproduction : dossier du projet.